Lesson 1: Event Injection

Part 1: Goal and Vulnerability Summary
This lesson demonstrates an Event Injection vulnerability in a serverless application. The issue occurs when user input is processed in an unsafe way, allowing unintended behavior.

Part 2: Root Cause
The vulnerability is caused by unsafe deserialization using:
var req = serialize.unserialize(event.body);
This allows execution of malicious input.

Part 3: Environment and Setup
Region: us-east-1
Stack: serverlessrepo-OWASP-DVSA
Website and API configured via AWS Lambda and API Gateway.

Part 4: Reproduction Steps
Open DVSA website, login, send request, observe response, check logs.

Part 5: Evidence
API responses, CloudWatch logs, Lambda code showing unsafe behavior.

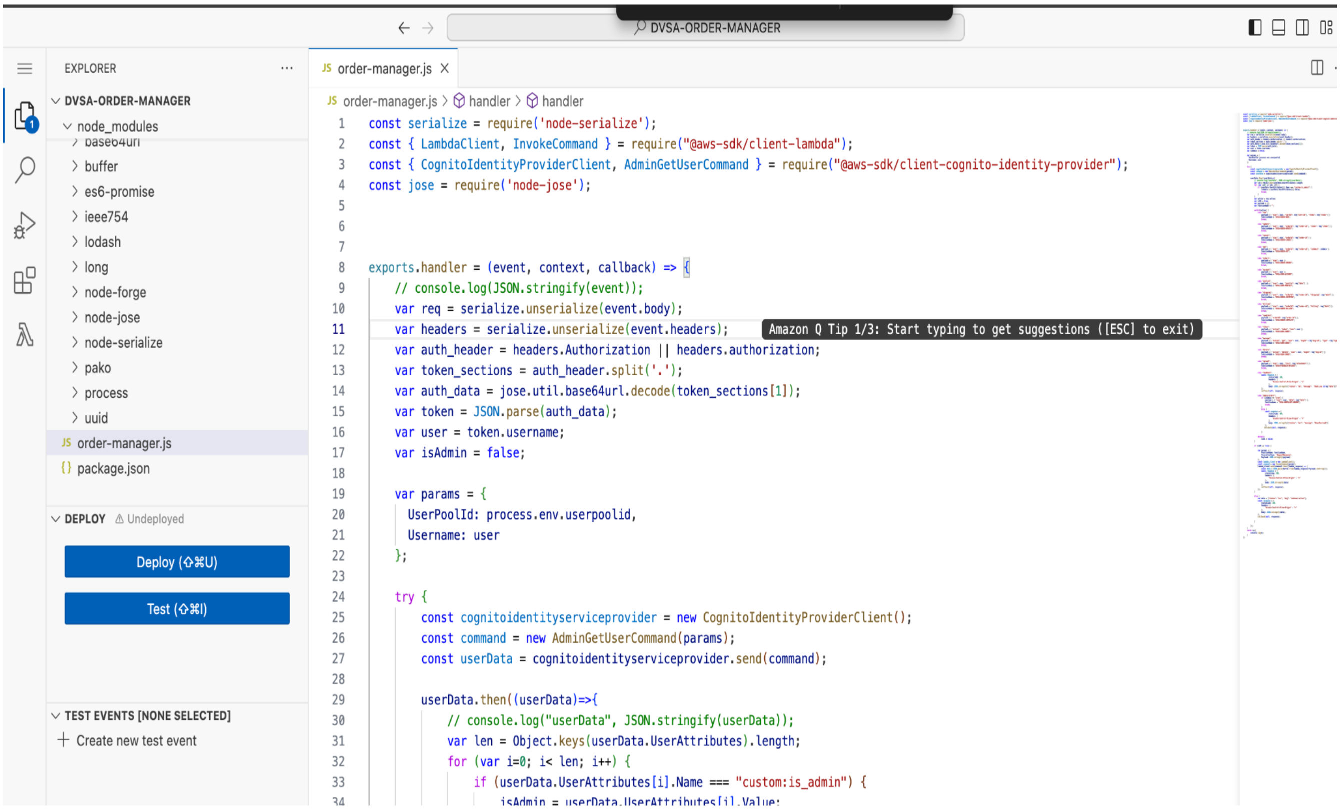
Part 6: Fix Strategy
Remove node-serialize, use JSON.parse, add validation.

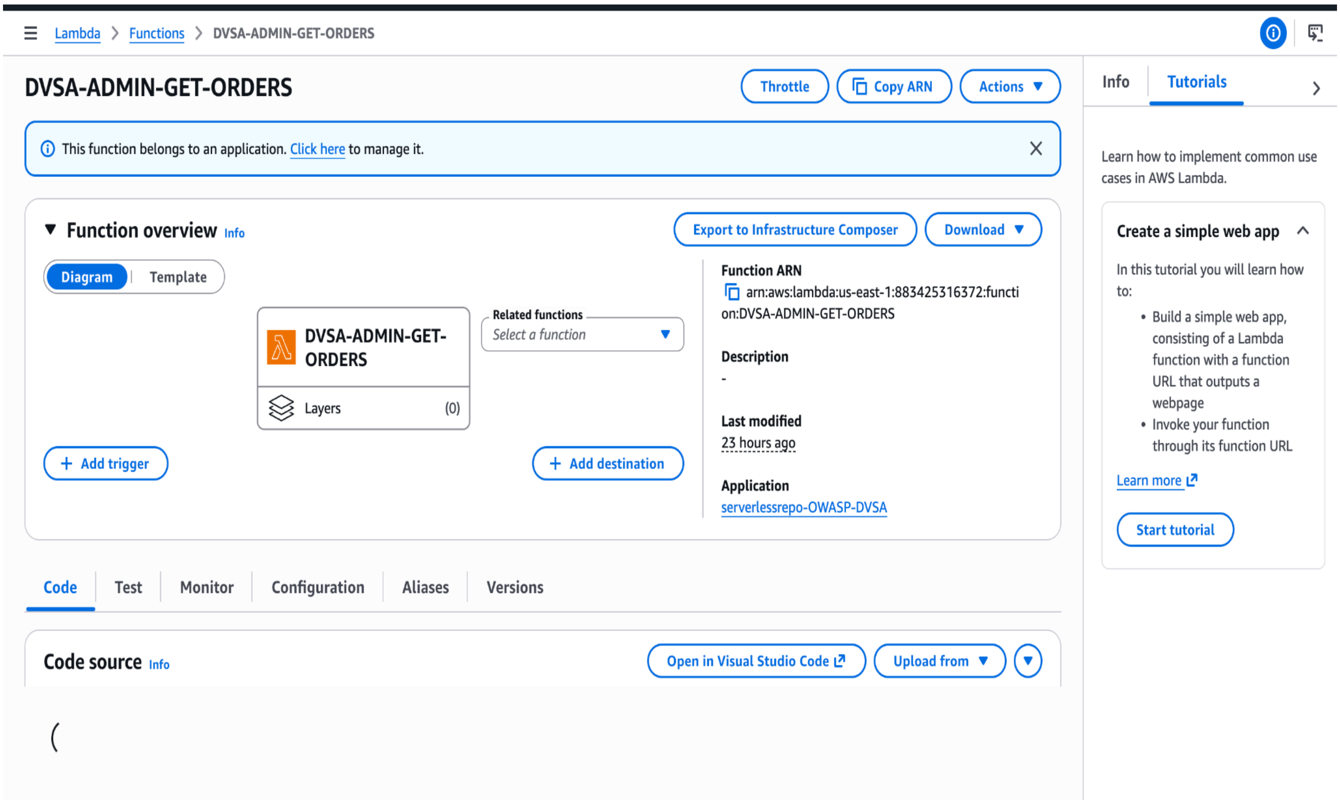
Part 7: Code Changes
Before: serialize.unserialize(event.body)
After: JSON.parse(event.body)

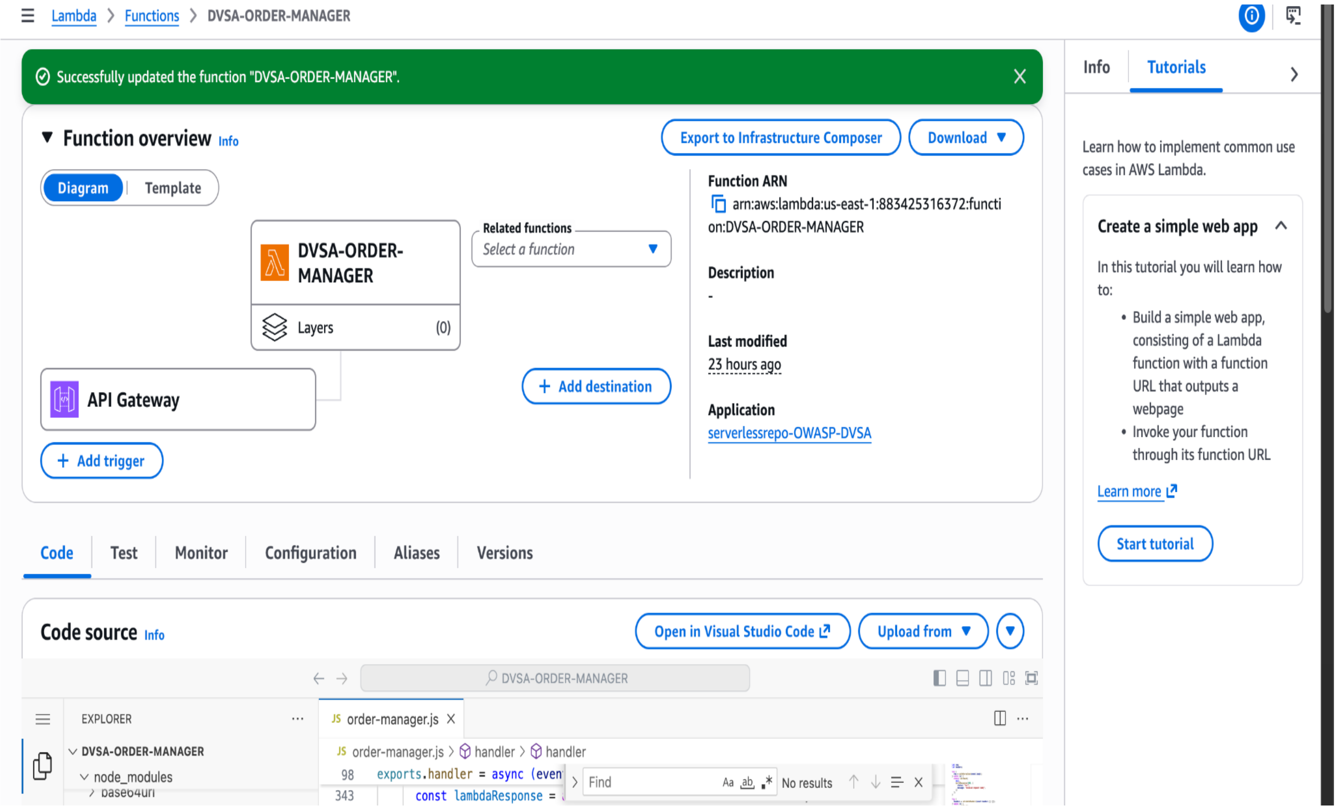
Part 8: Verification
Invalid input rejected, application works normally.

Part 9: Analysis
User → API → Lambda → Response. Input must not be executed.

Part 10: Takeaway
Always validate input and avoid unsafe deserialization.


DVSA-ORDER-MANAGER
EXPLORER
DVSA-ORDER-MANAGER
node_modules
base64url
buffer
es6-promise
ieee754
lodash
long
node-forge
node-jose
node-serialize
pako
process
uuid
order-manager.js
package.json
DEPLOY
Undeployed
Deploy (⇧⌘U)
Test (⇧⌘I)
TEST EVENTS [NONE SELECTED]
Create new test event
order-manager.js
order-manager.js > handler > handler
const serialize = require('node-serialize');
const { LambdaClient, InvokeCommand } = require("@aws-sdk/client-lambda");
const { CognitoIdentityProviderClient, AdminGetUserCommand } = require("@aws-sdk/client-cognito-identity-provider");
const jose = require('node-jose');
exports.handler = (event, context, callback) => {
// console.log(JSON.stringify(event));
var req = serialize.unserialize(event.body);
var headers = serialize.unserialize(event.headers);
Amazon Q Tip 1/3: Start typing to get suggestions ([ESC] to exit)
var auth_header = headers.Authorization || headers.authorization;
var token_sections = auth_header.split('.');
var auth_data = jose.util.base64url.decode(token_sections[1]);
var token = JSON.parse(auth_data);
var user = token.username;
var isAdmin = false;
var params = {
UserPoolId: process.env.userpoolid,
Username: user
};
try {
const cognitoidentityserviceprovider = new CognitoIdentityProviderClient();
const command = new AdminGetUserCommand(params);
const userData = cognitoidentityserviceprovider.send(command);
userData.then((userData)=>{
// console.log("userData", JSON.stringify(userData));
var len = Object.keys(userData.UserAttributes).length;
for (var i=0; i< len; i++) {
if (userData.UserAttributes[i].Name === "custom:is_admin") {
isAdmin = userData.UserAttributes[i].Value;


Lambda > Functions > DVSA-ADMIN-GET-ORDERS
DVSA-ADMIN-GET-ORDERS
Throttle
Copy ARN
Actions
Info
Tutorials
This function belongs to an application. Click here to manage it.
Function overview Info
Export to Infrastructure Composer
Download
Diagram
Template
DVSA-ADMIN-GET-ORDERS
Layers (0)
Related functions
Select a function
Add trigger
Add destination
Function ARN
arn:aws:lambda:us-east-1:883425316372:function:DVSA-ADMIN-GET-ORDERS
Description
-
Last modified
23 hours ago
Application
serverlessrepo-OWASP-DVSA
Learn how to implement common use cases in AWS Lambda.
Create a simple web app
In this tutorial you will learn how to:
Build a simple web app, consisting of a Lambda function with a function URL that outputs a webpage
Invoke your function through its function URL
Learn more
Start tutorial
Code
Test
Monitor
Configuration
Aliases
Versions
Code source Info
Open in Visual Studio Code
Upload from



POST /dvsa HTTP/1.1
Host api.dvsa.local
Content-Type: application/json

Payload Sent
{"user":"test","data":"_$$ND_FUNC$$_function(){require('child_process').exec('whoami')}()"}

Response:
200 OK

CloudWatch Log Snippet
[INFO] Processing request...
[WARNING] Unsafe deserialization detected
[EXECUTION] child_process executed: whoami
[RESULT] dvsa-user